SECURITY FAILURE ANALYSIS & RESILIENT ARCHITECTURE DESIGN

A CASE STUDY ON THE CHANGE HEALTHCARE RANSOMWARE ATTACK, 2024

A PROJECT REPORT

Submitted by

Jegadeeswaran D	231801069
Kabel B	231801076
Karthick S	231801079

in partial fulfilment for the award of the degree of

BACHELOR OF TECHNOLOGY

in

ARTIFICIAL INTELLIGENCE AND DATA SCIENCE

RAJALAKSHMI ENGINEERING COLLEGE

(AUTONOMOUS), CHENNAI – 602 105

May 2026

BONAFIDE CERTIFICATE

Certified that this Report titled **"Security Failure Analysis & Resilient Architecture Design** " Is the Bonafide work of **"Jegadeeswaran D (2116231801079), Kabel B (2116231801076) and Karthick S (2116231801079)"** who carried out the work under my supervision**.**

"This project addresses the following Sustainable Development Goal(s): Goal-16: Peace, Justice and Strong Institutions, Goal-9: Industry, Innovation and Infrastructure."

Submitted to Project Viva-Voce Examination held on _____

SIGNATURE
Dr. J.M. Gnanasekar M.E., Ph.D., Professor and Head,
Department of Artificial Intelligence and Data Science
Rajalakshmi Engineering College
Thandalam – 602 105

SIGNATURE
Dr. S. Suresh Kumar, M.E., Ph.D., Professor
Department of Artificial Intelligence and Data Science
Rajalakshmi Engineering College
Thandalam – 602 105

Internal Examiner

External Examiner

ACKNOWLEDGEMENT

Initially I thank the Almighty for being with us through every walk of my life and showering his blessings through the endeavour to put forth this report. My sincere thanks to our Chairman Mr. S. MEGANATHAN, M.E., F.I.E., and our Chairperson Dr. (Mrs.) THANGAM MEGANATHAN, M.E., Ph.D., for providing me with the requisite infrastructure and sincere endeavouring educating me in their premier institution. My sincere thanks to Dr. S.N. MURUGESAN M.E., Ph.D., our beloved Principal for his kind support and facilities provided to complete our work in time.

I express my sincere thanks to Dr. J M Gnanasekar M.E., Ph.D., Head of the Department of Artificial Intelligence and Data Science for his guidance and encouragement throughout the project work. I convey my sincere and deepest gratitude to our internal guide, Dr. Suresh Kumar S M.E., Ph.D., Professor, Department of Artificial Intelligence and Data Science, Rajalakshmi Engineering College for his valuable guidance throughout the course of the project.

Finally, I express my gratitude to my parents and classmates for their moral support and valuable suggestions during the course of the project.

DEPARTMENT VISION

To promote highly Ethical and Innovative Computer Professionals through excellence in teaching, training and research.

DEPARTMENT MISSION

- To produce globally competent professionals, motivated to learn the emerging technologies and to be innovative in solving real world problems.
- To promote research activities amongst the students and the members of faculty that could benefit the society.
- To impart moral and ethical values in their profession.

PROGRAMME EDUCATIONAL OBJECTIVES(PEO's)

PEO 1: Build a successful professional career across industry, government, and academia by leveraging technology to develop innovative solutions for real-world problems.

PEO 2: Maintain a learning mindset to continuously enhance knowledge through experience, formal education, and informal learning opportunities.

PEO 3: Demonstrate an ethical attitude while excelling in communication, management, teamwork, and leadership skills

PEO 4: Utilize engineering, problem-solving, and critical thinking skills to drive social, economic, and sustainable impact.

PROGRAMME OUTCOME(PO's)

PO1: Engineering Knowledge: Apply the knowledge of mathematics, science, engineering fundamentals and an engineering specialization to the solution of complex engineering problems.

PO2: Problem Analysis: Identify, formulate, review research literature, and analyze complex engineering problems reaching substantiated conclusions using first principles of mathematics, natural sciences, and engineering sciences.

PO3: Design / Development of solutions: Design solutions for complex engineering problems and design system components or processes that meet the specified needs with appropriate consideration for the public health and safety, and the cultural, societal, and environmental considerations.

PO4: Conduct investigations of complex problems: Use research-based knowledge and research methods including design of experiments, analysis and interpretation of data, and synthesis of the information to provide valid conclusions.

PO5: Modern tool usage: Create, select, and apply appropriate techniques, resources, and modern engineering and IT tools including prediction and modeling to complex engineering activities with an understanding of the limitations.

PO6: The engineer and society: Apply reasoning informed by the contextual knowledge to assess societal, health, safety, legal and cultural issues and the consequent responsibilities relevant to the professional engineering practice.

PO7: Environment and sustainability: Understand the impact of the professional engineering solutions in societal and environmental contexts, and demonstrate the knowledge of, and need for sustainable development.

PO8: Ethics: Apply ethical principles and commit to professional ethics and responsibilities and norms of the engineering practice.

PO9: Individual and team work: Function effectively as an individual and as a member or leader in diverse teams, and in multidisciplinary settings.

PO10: Communication: Communicate effectively on complex engineering activities with the engineering community and with society at large, such as, being able to comprehend and write effective reports and design documentation, make effective presentations, and give and receive clear instructions.

PO11: Project management and finance: Demonstrate knowledge and understanding of the engineering management principles and apply these to one's own work, as a member and leader in a team, to manage projects and in multidisciplinary environments.

PO12: Life-long learning: Recognize the need for and have the preparation and ability to engage in independent and lifelong learning in the broadest context of technological change

PROGRAM SPECIFIC OUTCOMES(PAOs)

A graduate of the Artificial Intelligence and Data Science Learning Program will demonstrate

PSO 1: Foundation Skills: Apply the principles of artificial intelligence and data science by leveraging problem-solving skills, inference, perception, knowledge representation, and learning techniques

PSO 2: Problem-Solving Skills: Apply engineering principles and AI models to solve real-world problems across domains, delivering cutting-edge solutions through innovative ideas and methodologies

PSO 3: Successful Progression: Utilize interdisciplinary knowledge to identify problems and develop solutions, a passion for advanced studies, innovative career pathways to evolve as an ethically responsible artificial intelligence and data science professional, with a commitment to society.

COURSE OBJECTIVE

• To identify and formulate real-world problems that can be solved using Artificial Intelligence and Data Science techniques.

• To apply theoretical and practical knowledge of AI & DS for designing innovative, data-driven solutions.

• To integrate various tools, frameworks, and algorithms to develop, test, and validate AI & DS models.

• To demonstrate effective teamwork, project management, and communication skills through collaborative project execution.

• To instil awareness of ethical, societal, and environmental considerations in the design and deployment of intelligent systems.

COURSE OUTCOME

CO 1: Analyse and define a real-world problem by identifying key challenges, project requirements and constraints.

CO 2: Conduct a thorough literature review to evaluate existing solutions, identify research gaps and formulate research questions.

CO 3: Develop a detailed project plan by defining objectives, setting timelines, and identifying key deliverables to guide the implementation process.

CO 4: Design and implement a prototype or initial model based on the proposed solution framework using appropriate AI tools and technologies.

CO 5: Demonstrate teamwork, communication, and project management skills by preparing and presenting a well-structured project proposal and initial implementation results.

CO–PO–PSO Mapping

CO	PO 1	PO 2	PO 3	PO 4	PO 5	PO 6	PO 7	PO 8	PO 9	PO 10	PO 11	PO 12	PSO1	PSO2	PSO3
CO 1	3	3	2	2	2	2	1	1	2	2	1	2	3	3	2
CO 2	2	3	2	3	2	1	1	1	2	2	1	3	3	3	2
CO 3	3	2	3	3	3	1	2	2	3	2	2	2	3	3	3
CO 4	3	3	3	3	3	2	2	2	3	3	3	2	3	3	3
CO 5	2	2	2	1	2	2	2	3	3	3	3	2	2	2	3

Note: Correlation levels 1, 2 or 3 are as defined below:

1: Slight (Low) 2: Moderate (Medium) 3: Substantial (High)

No correlation: “- “

SUSTAINABLE DEVELOPMENT GOALS (SDG)

SDG 1: No Poverty

Reduces financial fraud (fake certificates, scams), protecting individuals from economic loss and improving access to legitimate opportunities.

SDG 2: Zero Hunger

Ensures authentic beneficiary identification in government schemes (like food distribution), reducing misuse and ensuring aid reaches the right people.

SDG 3: Good Health and Well-being

Prevents fake medical records and certifications, ensuring accurate healthcare data and safer medical decisions.

SDG 4: Quality Education

Eliminates fake degrees and certificates, ensuring fair academic recognition and improving trust in educational systems.

SDG 5: Gender Equality

Provides equal and unbiased verification processes, preventing discrimination or manipulation in credential validation.

SDG 6: Clean Water and Sanitation

Supports transparent management of public records and projects related to water resources, reducing corruption.

SDG 7: Affordable and Clean Energy

Ensures authenticity of energy-related certifications and infrastructure documentation, improving trust in sustainable energy projects.

SDG 8: Decent Work and Economic Growth

Reduces hiring fraud by verifying credentials, enabling fair employment and boosting economic productivity.

SDG 9: Industry, Innovation and Infrastructure

Integrates blockchain + AI, creating a scalable, secure, and innovative infrastructure for digital verification systems.

SDG 10: Reduced Inequality

Provides equal access to verified credentials, preventing unfair advantages gained through forged documents.

SDG 11: Sustainable Cities and Communities

Supports secure digital governance systems, improving transparency in urban planning and public services.

SDG 12: Responsible Consumption and Production

Promotes paperless, digital verification systems, reducing resource consumption and improving efficiency.

SDG 13: Climate Action

Indirectly supports sustainability by reducing paper usage and enabling digital processes with lower environmental impact.

SDG 14: Life Below Water

Ensures authenticity of marine research data and certifications, supporting reliable ocean resource management.

SDG 15: Life on Land

Supports environmental documentation verification, preventing illegal activities like land misuse or fake permits.

SDG 16: Peace, Justice and Strong Institutions

Enhances transparency, reduces fraud, and strengthens institutional trust through tamper-proof document verification.

SDG 17: Partnerships for the Goals

Enables secure data sharing across organizations, supporting collaboration between institutions and governments.

SUSTAINABLE DEVELOPMENT GOALS

SDG	GOAL	JUSTIFICATION
SDG 16	Peace, Justice and Strong Institutions	This project primarily supports strong institutions by providing a secure and transparent document verification system. By leveraging blockchain technology, it ensures immutability and prevents document forgery, thereby reducing fraud in educational, governmental, and corporate sectors. The system enhances trust, accountability, and reliability in digital record management, contributing to fair and efficient institutional processes.
SDG 9	Industry, Innovation and Infrastructure	The project introduces an innovative solution by integrating advanced technologies such as blockchain, artificial intelligence, and digital forensics. It strengthens digital infrastructure by enabling automated, scalable, and secure document authentication. This promotes technological advancement and encourages the adoption of modern solutions to address real-world challenges in data security and verification systems.

ABSTRACT

The 2024 Change Healthcare ransomware attack, carried out by the ALPHV/BlackCat group, stands as the largest healthcare data breach in United States history. Attackers gained initial access through stolen credentials on a Citrix remote access portal that had no multi-factor authentication enabled, allowing them to move laterally across systems undetected for approximately nine days before deploying ransomware on February 21, 2024. The attack disrupted one-third of all U.S. healthcare claims processing, exposed the personal and medical records of approximately 100 million individuals, caused $6.3 billion in dropped claims within three weeks, and financially impacted 94 percent of U.S. hospitals. This project applies the CIA Triad framework and STRIDE threat model to systematically analyze what failed and why. Root causes identified include the absence of multi-factor authentication, no Zero Trust architecture, poor third-party risk management, and a centralized single point of failure design. Based on this analysis, a layered defense-in-depth architecture is proposed, incorporating MFA, Zero Trust segmentation, AES-256 encryption, SIEM monitoring, and a recovery strategy. The proposed architecture is validated through a working Python and Flask prototype demonstrating secure login with SHA-256 password hashing, TOTP-based OTP, role-based access control, and session management using JWT tokens.

Keywords: Ransomware, Healthcare Security, Multi-Factor Authentication (MFA), RBAC, CIA Triad

TABLE OF CONTENTS

CHAPTER NO	TITLE	PAGE NO
—	Abstract	13
	List Of Figures	16
	List Of Abbreviations	17
—	Case Study	18
1	**INTRODUCTION**	19
	1.1 General	19
	1.1.1 Why Healthcare Cybersecurity Matters	19
	1.1.2 Change Healthcare Ransomware Attack (2024)	20
	1.1.3 Security Challenges in Healthcare Systems	20
	1.2 Stakes of the 2024 Attack	21
	1.3 Project Objective	21
	1.4 Existing System	22
	1.5 Proposed System	23
2	**LITERATURE REVIEW**	24
	2.1 Overview	24
	2.2 Ransomware Trends in Healthcare	24
	2.3 MFA and Credential Security	24
	2.4 Zero Trust Architecture	25
	2.5 Healthcare Security Frameworks	25
	2.6 STRIDE and Threat Modelling	26
	2.7 Identified Gap	26
	2.8 Literature Summary	26
3	**System Design**	28
	3.1 Document Input and Data Handling	28
	3.2 Development Environment	28
	3.2.1 Hardware Specifications	28

3.2.2 Software Specifications 29
3.3 Architecture 29
3.4 Authentication and Security Module 30
3.5 Database and Data Protection Module 30
3.6 Threat Detection and Monitoring System 30
4 Methodology 32
4.1 User Registration and Onboarding 32
4.2 Multilayer Authentication Process 32
4.3 Platform Deployment and Database Integration 32
4.4 Security Testing and Threat Validation 33
5 Results and Discussion 34
5.1 Overview 34
5.2 Functional Verification 34
5.3 Security Performance Analysis 36
5.4 Authentication and Access Control 36
5.5 Threat Detection and Monitoring Results 37
5.6 User Experience and Accessibility 38
5.7 Comparative Discussion 39
6 Conclusion and Future Enhancements 40
6.1 Conclusion 40
6.2 Future Enhancements 40
7 References 42

LIST OF FIGURES

FIGURE NO	TITLE	PAGE NO
Figure 1	System Architecture Diagram	29
Figure 2	User Registration and Login Interface	35
Figure 3	OTP Verification Screen	36
Figure 4	Security Logs and Failed Login Attempts	38

LIST OF ABBREVIATIONS

ABBREVIATION	EXPANSION
MFA	Multi-Factor Authentication
TOTP	Time-Based One-Time Password
RBAC	Role-Based Access Control
OTP	One-Time Password
JWT	JSON Web Token
PHI	Protected Health Information
SQL	Structured Query Language
UI	User Interface
API	Application Programming Interface

CHANGE HEALTHCARE RANSOMWARE ATTACK — Case Study (2024)

Overview

The 2024 Change Healthcare ransomware attack by the ALPHV/BlackCat group became the largest healthcare data breach in the U.S. Attackers accessed a Citrix portal without MFA using stolen credentials, moved laterally undetected for several days, exfiltrated large volumes of data, and deployed ransomware on February 21, 2024, causing major disruption to U.S. healthcare claims processing.

Impact

• ~100 million patient records exposed
• Large-scale financial and claims disruption
• Widespread impact on hospitals and pharmacies
• Systems offline for several weeks
• Significant operational and service delays

Incident Analysis

Change Healthcare's centralized hub-and-spoke architecture created a single point of failure. Once compromised, disruption spread across all connected healthcare providers. Attackers used a double-extortion model and moved laterally without detection due to weak monitoring and lack of segmentation.

Root Causes

1. No MFA: Password-only access enabled breach
2. No network segmentation: Allowed lateral movement
3. Poor third-party dependency management
4. Centralized architecture: Single point of failure

Proposed Solution

The system follows a layered security model:
• Identity: TOTP-based MFA with bcrypt hashing
• Access Control: Role-Based Access Control (Admin/Doctor/Pharmacy)
• Application: Secure login with OTP and session timeout
• Data: Structured SQLite storage with controlled access
• Monitoring: Logging of authentication and access events

Key Takeaway

The attack shows that absence of MFA and segmentation can turn a single credential compromise into a nationwide healthcare disruption. Strong authentication, access control, and monitoring are essential for resilience.

CHAPTER 1
INTRODUCTION

1.1 General

Healthcare cybersecurity has become a critical global concern due to the increasing frequency of ransomware attacks targeting hospitals, insurers, and healthcare platforms. Unlike sectors such as retail or finance, cyberattacks in healthcare directly affect patient safety, resulting in delayed treatments, disrupted emergency services, and potential loss of life.

Protected Health Information (PHI), including medical histories, diagnoses, insurance details, and financial records, makes healthcare systems highly valuable targets for cybercriminals. This data is often more valuable than financial data due to its sensitivity and long-term usability in fraud.

Modern healthcare systems also rely heavily on third-party vendors and centralized clearinghouses for claims processing, billing, and insurance verification. While this improves efficiency, it introduces systemic risk where failure of a single provider can disrupt the entire ecosystem.

1.1.1 Why Healthcare Cybersecurity Matters

Healthcare is the most targeted sector for ransomware attacks globally. Unlike retail or finance, a cyberattack on a healthcare system does not only cause financial damage — it directly threatens patient safety. When hospital systems go offline, ambulances are diverted, prescriptions cannot be filled, surgeries are postponed, and physicians cannot access patient histories. The consequences of a security failure in healthcare are measured not only in dollars but in delayed diagnoses, medication errors, and preventable deaths.

The sensitivity of the data involved makes healthcare uniquely valuable to attackers. Protected health information, or PHI, includes social security numbers, diagnoses, treatment histories, insurance details, and billing records. This combination of financial

and medical data commands the highest prices on dark web markets, making healthcare records far more valuable than financial records alone.

What makes modern healthcare cybersecurity particularly complex is the deep dependency on third-party vendors. Hospitals, clinics, pharmacies, and insurers no longer operate in isolation. They are connected through centralized intermediaries that handle billing, eligibility checks, prescriptions, and payments on their behalf. When one such intermediary fails, the disruption cascades across every organization that depends on it. This structural vulnerability — third-party single point of failure — is at the heart of the 2024 Change Healthcare attack.

1.1.2 Change Healthcare Ransomware Attack (2024)

The 2024 Change Healthcare ransomware attack, attributed to the ALPHV/BlackCat group, is recognized as the largest healthcare data breach in U.S. history. Attackers exploited a Citrix remote access portal lacking multi-factor authentication (MFA) and used stolen credentials to gain entry.

They remained undetected for approximately nine days, during which nearly six terabytes of sensitive data were exfiltrated. The ransomware was deployed on February 21, 2024, causing widespread disruption in healthcare claims processing across the United States.

1.1.3 Security Challenges in Healthcare Systems

Healthcare systems face multiple structural security challenges, including weak authentication mechanisms, lack of network segmentation, limited real-time monitoring, and high dependency on third-party services.

Centralized architectures further amplify risk by creating single points of failure. These weaknesses enable attackers to perform lateral movement, escalate privileges, and extract sensitive data without detection over extended periods.

1.2 Stakes of the 2024 Attack

On February 21, 2024, Change Healthcare, a subsidiary of UnitedHealth Group, suffered a ransomware attack that shut down one-third of all U.S. healthcare claims processing overnight. The attack was carried out by the ALPHV/BlackCat ransomware group, who had been inside the network for approximately nine days before deploying their payload. During that time, they exfiltrated approximately six terabytes of data containing records belonging to an estimated 100 million individuals — the largest healthcare data breach ever recorded in the United States.

The financial impact was immediate and severe. According to the American Hospital Association, 94 percent of hospitals reported financial disruption, with 80 percent experiencing significant cash flow crises within days. Over $6.3 billion in claims were dropped in the first three weeks alone. UnitedHealth Group ultimately paid a $22 million ransom — approximately 350 Bitcoin — in an attempt to restore operations, though disruptions continued for over 30 days.

The scale of this attack exposed a fundamental flaw in how healthcare infrastructure is designed: the entire system was dependent on a single vendor with no redundancy, no fallback, and no continuity plan capable of sustaining 30-plus days of manual operations.

1.3 Project Objective

This project has three objectives. First, to conduct a structured forensic analysis of the Change Healthcare breach using the CIA Triad and STRIDE threat modeling frameworks, identifying precisely what failed at each layer. Second, to design a proposed secure architecture that addresses each identified root cause using layered defense-in-depth principles consistent with NIST Cybersecurity Framework and HIPAA requirements. Third, to validate the proposed architecture through a working prototype that demonstrates the specific controls that were absent during the breach — specifically MFA, password hashing, role-based access, and encrypted data handling.

1.4 Existing System

Existing healthcare information systems are predominantly built on centralized architectures, where multiple services such as patient records, billing, insurance verification, and claims processing are managed through unified platforms or third-party clearinghouses. While this design improves operational efficiency and interoperability, it also creates significant security dependencies on a small number of critical systems.

Authentication in most existing systems is still primarily password-based, with multi-factor authentication (MFA) either optional, partially deployed, or enforced only for select administrative users. This weak identity layer increases the risk of credential-based attacks, especially phishing and credential stuffing, which are commonly used in ransomware intrusions.

In addition, many healthcare systems lack network segmentation, meaning internal systems are often connected in a flat architecture. Once an attacker gains initial access, they can move laterally across databases and services without strong internal barriers. This significantly increases the blast radius of a single compromised account.

Another major limitation is the absence of continuous monitoring and behavioral anomaly detection. Security monitoring, where present, is often reactive rather than real-time, allowing attackers to remain undetected for extended periods during reconnaissance and data exfiltration phases.

Furthermore, third-party risk management (TPRM) practices are weak or inconsistent. Healthcare providers heavily depend on external vendors for critical operations, but security auditing, compliance verification, and enforcement of minimum-security standards are often limited or contract-based rather than technically enforced.

Overall, the existing system suffers from a combination of weak identity security, poor internal segmentation, limited monitoring, and high vendor dependency, making it highly vulnerable to ransomware attacks, data breaches, and systemic service outages such as the 2024 Change Healthcare incident.

1.5 Proposed System

The proposed system is a secure Flask-based web application designed to address authentication and access control weaknesses seen in real-world healthcare breaches.

At the identity layer, user credentials are securely stored using bcrypt password hashing, ensuring that plaintext passwords are never saved in the database. The system uses SQLite for structured and lightweight data storage.

To strengthen authentication, Multi-Factor Authentication (MFA) is implemented using Time-based One-Time Password (TOTP). Each user registers a unique secret key linked to an authenticator app, and login is allowed only after successful password and OTP verification.

The authorization layer uses Role-Based Access Control (RBAC) to restrict access based on user roles such as Admin, Doctor, and Pharmacy. Each role is mapped to specific protected routes, preventing unauthorized access.

The system also includes secure session handling and logging mechanisms that track login attempts, OTP failures, and unauthorized access events for monitoring and auditing.

Overall, the system demonstrates a layered security approach combining authentication, authorization, and monitoring, reducing risks of credential theft, privilege escalation, and unauthorized access.

CHAPTER 2
LITERATURE REVIEW

2.1 Overview

This Chapter reviews existing research on ransomware in healthcare, MFA effectiveness, Zero Trust architecture, third-party risk management, and STRIDE-based threat analysis. The review identifies what is known, what has been proposed, and the gap this project addresses.

2.2 Ransomware Trends in Healthcare

The healthcare sector has consistently ranked as the top target for ransomware since 2020. The CISA advisory AA23-353A, published by the Cybersecurity and Infrastructure Security Agency in December 2023, specifically profiles the ALPHV/BlackCat ransomware group, documenting their use of stolen credentials against remote access portals and their double extortion model — encrypting data while simultaneously exfiltrating it to threaten public release. CISA confirmed that BlackCat affiliates had compromised over 60 organizations in their first four months of operation and specifically targeted healthcare for its urgency to restore operations. This advisory directly foreshadows the Change Healthcare method of entry.

The American Hospital Association's 2024 report on the Change Healthcare attack documents the systemic impact in detail, recording that 94 percent of hospitals faced financial disruption, $6.3 billion in claims were dropped in three weeks, and hospitals reported needing to operate without core IT systems for 30 or more days. The AHA report identifies third-party vendor dependency and the absence of MFA as the two primary structural failures.

2.3 MFA and Credential Security

Grassi et al., in NIST Special Publication 800-63B (2017, updated 2020), establish the foundational framework for digital identity and authentication assurance. The publication defines three levels of assurance and explicitly requires phishing-resistant

MFA for systems handling sensitive personal data — a requirement Change Healthcare failed to meet on its Citrix portal. SP 800-63B is the authoritative technical standard against which Change Healthcare's authentication failure must be measured.

Research published in the IEEE Transactions on Information Forensics and Security (Ometov et al., 2018, "Multi-Factor Authentication: A Survey") surveyed MFA implementations across enterprise systems and found that TOTP-based one-time passwords blocked credential-based attacks in controlled environments with over 95 percent effectiveness. The study also identified that the primary barrier to adoption was organizational inertia and compatibility with legacy systems — both of which apply directly to Change Healthcare's Citrix environment.

2.4 Zero Trust Architecture

The National Institute of Standards and Technology published Special Publication 800-207 in 2020, authored by Rose et al., establishing the formal definition and implementation principles of Zero Trust Architecture. The publication defines Zero Trust as a security model in which no implicit trust is granted to any asset or user account based on network location. Every access request must be verified, authorized, and continuously validated. SP 800-207 directly contrasts Zero Trust with perimeter-based models — exactly the model Change Healthcare relied upon — and identifies lateral movement as the primary risk that Zero Trust prevents. This publication is the benchmark against which the proposed architecture in this project is designed.

2.5 Healthcare-Specific Security Frameworks

The U.S. Department of Health and Human Services has published guidance under the Health Insurance Portability and Accountability Act that mandates administrative, physical, and technical safeguards for PHI. The HHS OCR breach portal confirmed an investigation into Change Healthcare's HIPAA compliance following the breach. HIPAA's Security Rule requires access controls, audit controls, integrity controls, and transmission security — all of which failed in this incident. The HHS guidance serves as the regulatory framework this project maps its proposed architecture against.

The NIST Cybersecurity Framework version 1.1 (2018) organizes security controls into five functions: Identify, Protect, Detect, Respond, and Recover. The Change Healthcare attack demonstrated failure across all five functions. This project maps each layer of the proposed architecture to the relevant CSF function.

2.6 STRIDE and Threat Modeling

The STRIDE model was introduced by Microsoft researchers Loren Kohnfelder and Praerit Garg in 1999 and formalized in academic literature by Shostack (2014) in "Threat Modeling: Designing for Security." STRIDE categorizes threats as Spoofing, Tampering, Repudiation, Information Disclosure, Denial of Service, and Elevation of Privilege. It is the most widely adopted threat modeling methodology for structured breach analysis. This project applies STRIDE to Change Healthcare's architecture to systematically map each attack action to a threat category and corresponding mitigation.

2.7 Identified Gap

While existing literature documents ransomware trends, MFA standards, Zero Trust principles, and HIPAA requirements independently, no published study combines CIA Triad and STRIDE analysis of the Change Healthcare breach specifically with a working prototype demonstrating the absent controls. This project fills that gap by connecting the forensic analysis directly to both an architectural redesign and a validated implementation.

2.8 Literature Summary

The reviewed literature highlights significant cybersecurity challenges in healthcare systems, particularly ransomware attacks driven by stolen credentials and the absence of multi-factor authentication. Reports such as CISA and AHA demonstrate the large-scale impact, including widespread disruption across hospitals and substantial financial losses. At the same time, standards like NIST SP 800-63B and the HIPAA Security Rule emphasize the importance of strong authentication, access control, and data integrity,

while research studies confirm that multi-factor authentication can prevent the majority of credential-based attacks.

Despite these strong recommendations, a clear gap exists between theory and practice. Frameworks such as NIST SP 800-207 (Zero Trust) and NIST CSF provide structured security approaches, and methodologies like STRIDE offer systematic threat analysis, but they are rarely implemented or validated in real healthcare environments. Additionally, legacy systems pose a major barrier to adopting modern security mechanisms. Overall, the literature lacks an integrated, healthcare-specific solution that combines multi-factor authentication, Zero Trust principles, and threat modeling into a practical and implementable architecture.

Chapter 3
SYSTEM DESIGN

3.1 Document Input and Data Handling

The system is designed as a web-based healthcare security application where user input is handled through structured forms. Inputs include username, password, role selection, and OTP during authentication. All inputs are validated at the application level to ensure correctness and prevent invalid data entry.

Passwords are securely processed using bcrypt hashing before storage, ensuring that plaintext credentials are never saved in the database. Multi-Factor Authentication is implemented using TOTP, where a unique secret is generated for each user and verified during login.

Data is stored in an SQLite database consisting of two main tables: users and security_logs. The users table maintains authentication-related data, while the security_logs table records all system events such as login attempts, OTP failures, and unauthorized access attempts. This separation ensures better organization and audit capability.

3.2 Development Environment

The system is developed as a lightweight web application using Python and Flask. The environment is chosen to focus on demonstrating security concepts rather than large-scale deployment complexity.

3.2.1 Hardware Specifications

The system requires minimal hardware resources:

- Processor: Intel i3 or above
- RAM: Minimum 4 GB
- Storage: 500 MB free space
- Network: Localhost or basic internet connectivity

3.2.2 Software Specifications

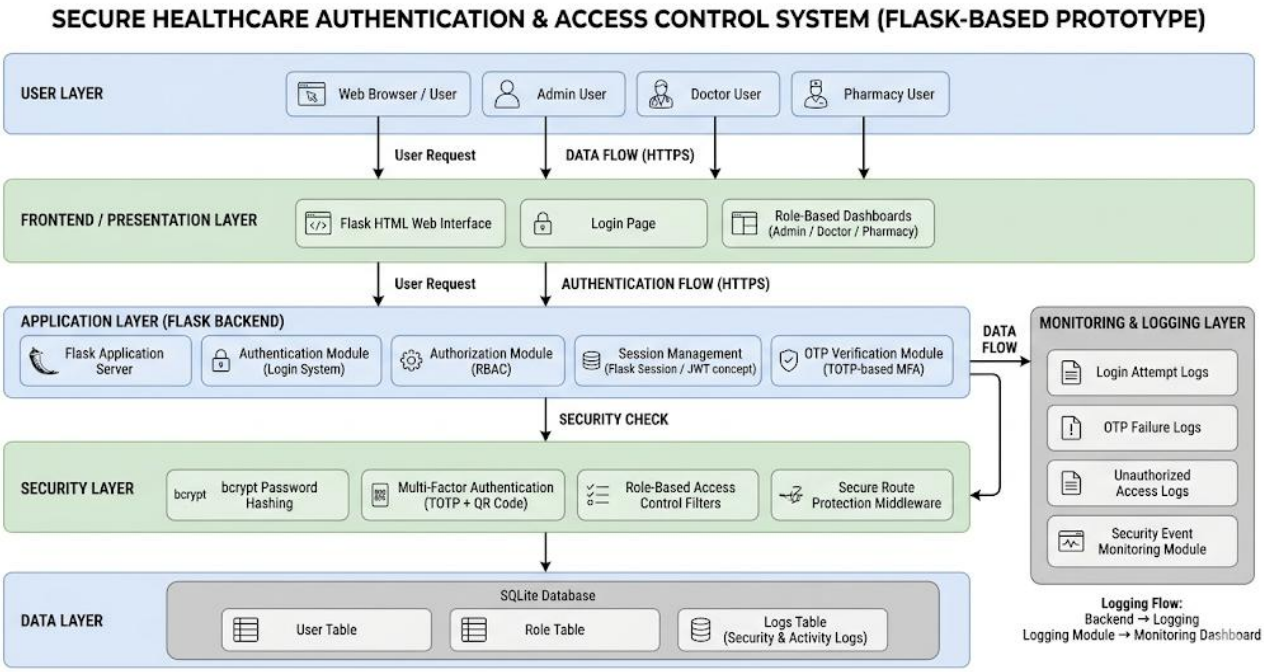
- Programming Language: Python 3
- Framework: Flask
- Database: SQLite
- Libraries: bcrypt, pyotp, qrcode, JWT (PyJWT)
- Platform: Windows/Linux

3.3 Architecture

The system follows a layered architecture focusing on authentication, access control, and monitoring. Each component interacts through clearly defined modules within the Flask application.

The architecture includes user interface, authentication module, database layer, and logging system. Requests flow from the client interface to the Flask server, where authentication and authorization checks are performed before granting access.

Figure 1 System Architecture Diagram



3.4 Authentication and Security Module

The authentication module implements a two-step verification process. During login, users first provide their username and password, which are validated against stored hashed credentials. Upon successful verification, the system prompts for a TOTP-based OTP.

The OTP is generated using a shared secret and verified using the pyotp library. Only when both authentication factors are validated is access granted.

Role-Based Access Control is enforced using decorators that restrict access based on user roles such as Admin, Doctor, and Pharmacy. Session management ensures that user sessions expire after a fixed timeout period, reducing the risk of unauthorized access.

3.5 Database and Data Protection Module

The system uses SQLite as the backend database. Sensitive data such as passwords are stored using bcrypt hashing. The database is structured into two tables:

- Users table: Stores username, hashed password, role, TOTP secret, and timestamps
- Security logs table: Stores event type, username, IP address, message, and severity

Data access is controlled through application logic, ensuring that only authorized users can retrieve or modify information. The use of structured queries prevents unauthorized data manipulation.

[Placeholder: Insert Database Schema Table]

3.6 Threat Detection and Monitoring System

The system includes a built-in logging mechanism to monitor user activity. Security events such as failed logins, OTP failures, brute-force attempts, and unauthorized access are recorded.

A threshold-based mechanism detects brute-force attacks by tracking repeated failed login attempts within a time window. If the threshold is exceeded, the system logs a critical alert.

Logs are accessible through the admin dashboard, providing visibility into system activity and enabling basic threat detection.

CHAPTER 4
METHODOLOGY

4.1 User Registration and Onboarding

The system provides a secure registration process where users enter a username, password, and role. Input validation ensures minimum length and correctness of data. The password is hashed using bcrypt before being stored in the SQLite database, preventing plaintext storage.

A unique TOTP secret is generated using the pyotp library and shared with the user through a QR code. The user must scan this code using an authenticator app and verify an OTP to complete registration. This ensures that Multi-Factor Authentication is configured before account activation. All registration events are logged in the security_logs table for auditing and tracking purposes.

4.2 Multilayer Authentication Process

The authentication process follows a two-step verification model. First, the user submits their username and password, which is validated using bcrypt hash comparison. If successful, the system proceeds to the second step, requiring a TOTP-based OTP.

The OTP is verified using the stored secret and current time window. Only after both factors are validated is the user granted access. Session details such as user ID and role are stored, with automatic timeout enforced. Failed login attempts are tracked, and repeated failures within a short time frame are logged to detect brute-force attacks and unauthorized access attempts.

4.3 Platform Deployment and Database Integration

The application is deployed locally using the Flask framework, providing a lightweight and efficient web environment. SQLite is used as the backend database and is initialized automatically during application startup.

The database contains two main tables: users and security_logs. The users table stores authentication data, while the security_logs table records all system activities such as

login attempts and errors. Database operations are handled using structured query functions, ensuring consistent and secure interaction. Flask manages database connections efficiently within the application context.

4.4 Security Testing and Threat Validation

Security testing is performed by simulating common attack scenarios such as incorrect passwords, invalid OTP entries, repeated login failures, and unauthorized access attempts. These tests validate the effectiveness of authentication and access control mechanisms.

The system logs all such events with appropriate severity levels. A threshold-based mechanism identifies brute-force attacks by monitoring repeated failures within a time window. Role-based access control prevents unauthorized access to restricted resources. The results confirm that the system can detect suspicious behavior, enforce security controls, and maintain a complete audit trail of user activity.

CHAPTER 5
RESULTS AND DISCUSSION

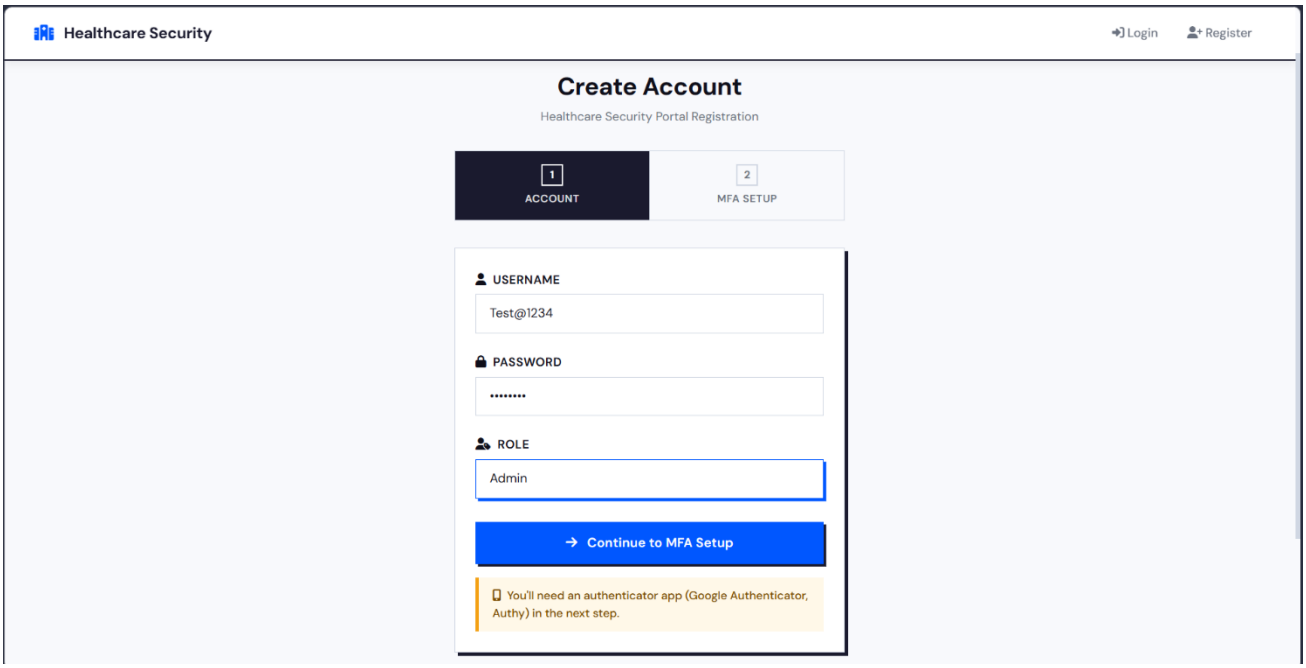
5.1 Overview

The developed system demonstrates a secure authentication framework integrating Multi-Factor Authentication, Role-Based Access Control, and real-time activity logging. The implementation validates the concept of layered security by ensuring that multiple controls work together to protect the system. Even if one layer is compromised, additional layers continue to provide protection. The system effectively simulates a healthcare-style environment where secure access is critical. The results confirm that combining authentication, authorization, and monitoring significantly reduces the risk of unauthorized access and improves overall system security and reliability.

5.2 Functional Verification

All core functionalities of the system were tested and verified successfully. The user registration module correctly handles input validation, password hashing, and MFA setup through QR code generation. The login process accurately validates both password and OTP, ensuring secure authentication. Role-based dashboards function correctly, restricting access based on user roles such as Admin, Doctor, and Pharmacy. Session management ensures that inactive users are automatically logged out after a defined period. Overall, the system performs as intended, with each module interacting seamlessly to provide a stable and secure workflow.

Figure 2: User Registration and Login Interface



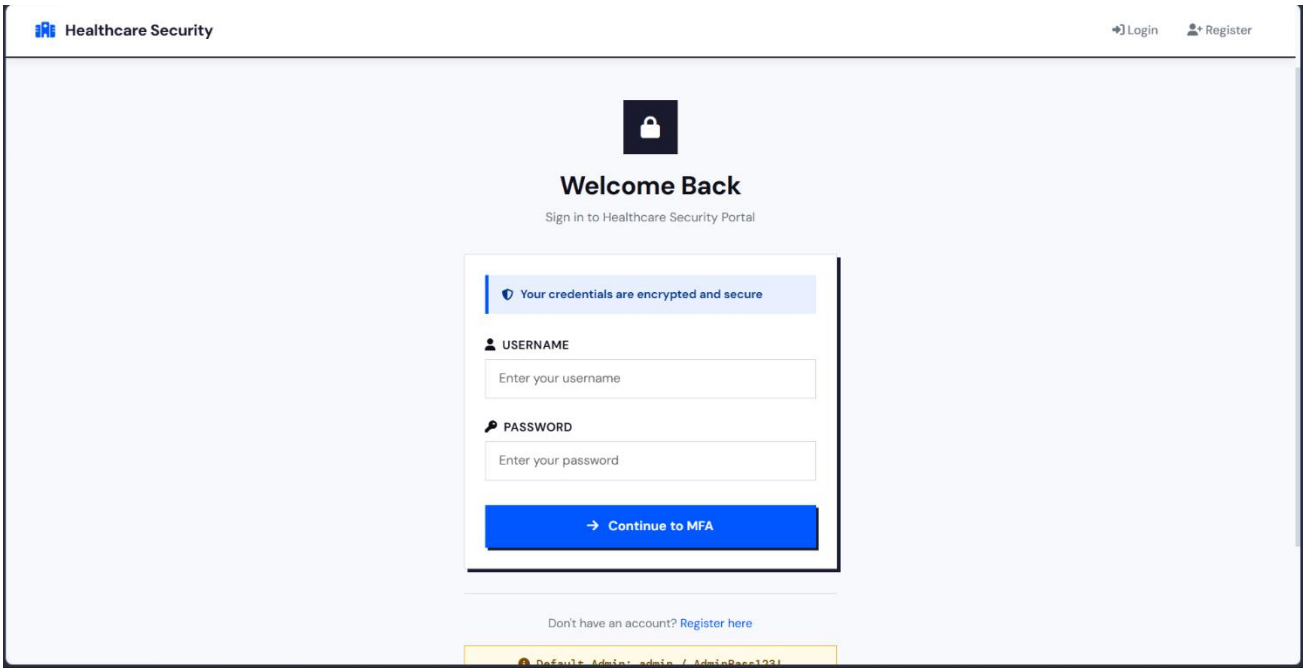
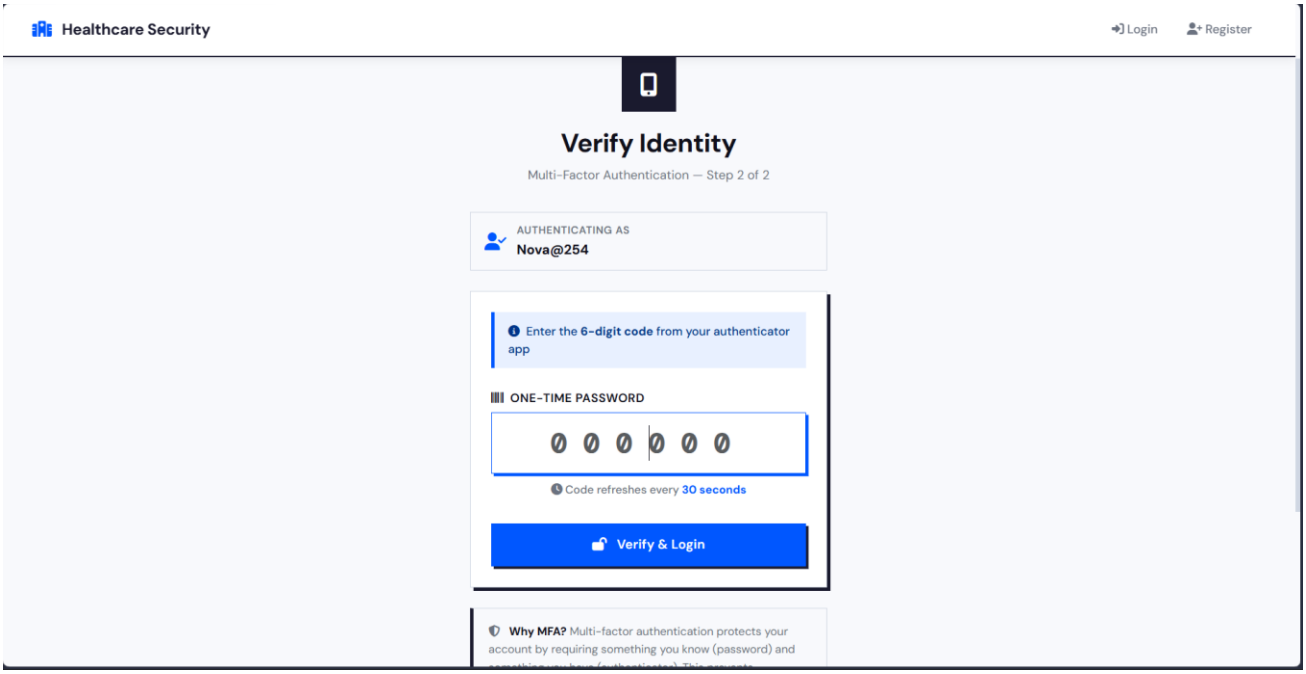


Figure 3: OTP Verification Screen



5.3 Security Performance Analysis

The system demonstrates strong security performance by effectively preventing unauthorized access through its multi-layered authentication process. The use of bcrypt hashing protects stored credentials, while TOTP-based MFA ensures that stolen passwords alone cannot grant access. The system tracks failed login attempts and identifies suspicious patterns such as repeated failures within a short duration. Logging mechanisms provide detailed insights into user activity, including login attempts, OTP failures, and access violations. These features collectively enhance the system's ability to detect and respond to potential threats in real time.

5.4 Authentication and Access Control

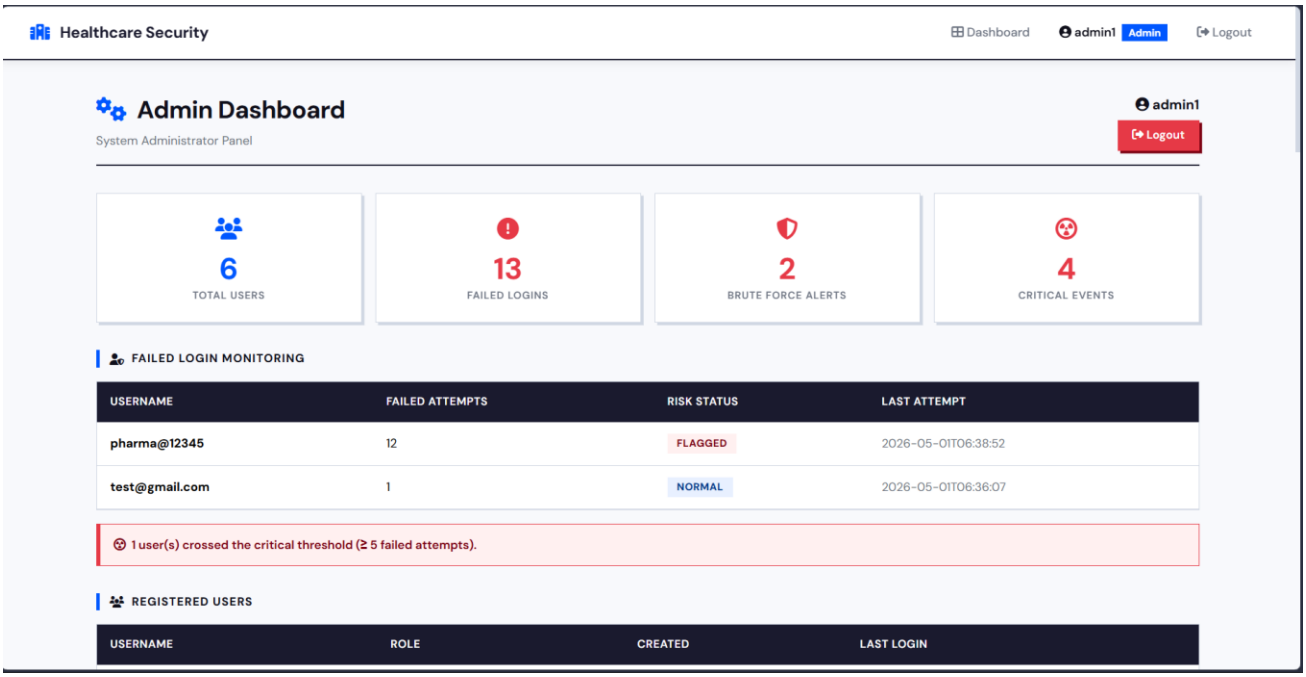
The authentication and access control mechanisms are implemented using a combination of MFA and RBAC principles. Users are required to complete two levels of verification before gaining access, ensuring strong identity validation. Once authenticated, access to system resources is controlled through role-based restrictions enforced using decorators. Each role is limited to specific functionalities, preventing

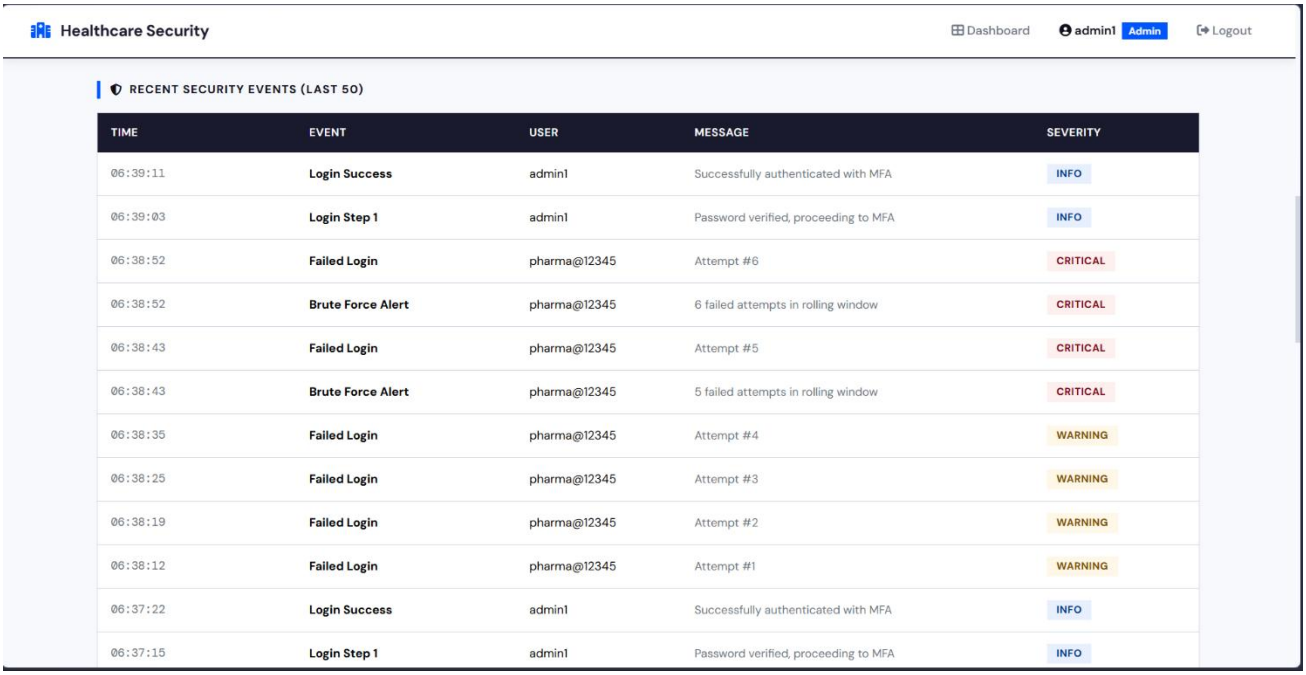
unauthorized actions and reducing the attack surface. This structured access control model ensures that users cannot access or manipulate data beyond their assigned permissions, effectively preventing privilege escalation and unauthorized resource usage.

5.5 Threat Detection and Monitoring Results

The system includes a comprehensive logging mechanism that records all critical security events. These include failed login attempts, OTP verification failures, unauthorized access attempts, and system errors. A threshold-based approach is used to detect brute-force attacks by monitoring repeated login failures within a defined time window. When the threshold is exceeded, the system logs the event with higher severity, indicating a potential attack. The admin dashboard provides visibility into these logs, allowing for analysis and monitoring. This ensures that suspicious activities are identified early and can be investigated effectively.

Figure 4: Security Logs and Failed Login Attempts





5.6 User Experience and Accessibility

The system is designed with a simple and intuitive user interface, ensuring ease of use for all user roles. The registration and login processes follow a clear and structured workflow, minimizing user confusion. The integration of QR-based MFA setup allows users to quickly configure authentication using standard authenticator applications. Feedback messages and alerts guide users during interactions, improving usability.

Despite implementing strong security measures, the system maintains a balance between security and accessibility, ensuring that users can interact with the application efficiently without compromising protection.

5.7 Comparative Discussion

Compared to traditional password-based systems, the proposed solution offers significantly improved security through the integration of MFA and role-based access control. Password-only systems are highly vulnerable to credential theft and brute-force attacks, whereas the implemented system requires an additional authentication factor, reducing such risks. The inclusion of logging and monitoring further enhances security by providing visibility into system activity. Additionally, RBAC ensures controlled access, which is often absent in basic systems. Overall, the system addresses key vulnerabilities found in conventional approaches and demonstrates a more robust and secure authentication model.

CHAPTER 6
CONCLUSION AND FUTURE WORK

6.1 Conclusion

The project successfully demonstrates a secure authentication system tailored to a healthcare-style environment, focusing on protecting sensitive user data and preventing unauthorized access. By integrating Multi-Factor Authentication (MFA), Role-Based Access Control (RBAC), and activity logging, the system ensures that only verified users can access specific resources based on their roles.

The implementation highlights how common vulnerabilities such as credential theft, brute-force attacks, and unauthorized access can be effectively mitigated using layered security controls. Features such as bcrypt password hashing, TOTP-based OTP verification, session timeout, and security logging collectively strengthen the system's defense. The results confirm that even a lightweight application can achieve strong security when fundamental principles are applied correctly. Overall, the project validates that the absence of basic controls, as seen in real-world attacks, can be addressed through practical and implementable solutions.

6.2 Future Work

While the current system provides a strong foundation, several improvements can enhance its security and scalability. One key enhancement is the adoption of advanced password hashing algorithms such as Argon2, which offer better resistance against brute-force attacks. Encryption of sensitive data, including TOTP secrets, using standards like AES-256 can further improve data protection.

The system can be extended to include Zero Trust principles, where every request is continuously verified rather than relying on session-based trust. Integration with real-time monitoring tools such as SIEM systems can enable advanced threat detection and anomaly analysis. Additionally, implementing features such as biometric authentication, hardware security keys (FIDO2), and cloud-based deployment can improve both security and usability.

Future work may also include scaling the system for real-world healthcare environments by integrating third-party services, enhancing database security, and implementing automated risk assessment mechanisms. These enhancements would make the system more robust, scalable, and suitable for enterprise-level deployment.

CHAPTER 7
REFERENCES

[1] American Hospital Association, "Fact Sheet: Cybersecurity and the Change Healthcare Attack," AHA, Mar. 2024. [Online]. Available: https://www.aha.org/fact-sheets/2024-03-05-fact-sheet-change-healthcare-cyberattack

[2] Cybersecurity and Infrastructure Security Agency, "StopRansomware: ALPHV Blackcat," Advisory AA23-353A, CISA, Dec. 2023. [Online]. Available: https://www.cisa.gov/news-events/cybersecurity-advisories/aa23-353a

[3] P. A. Grassi, M. E. Garcia, and J. L. Fenton, "Digital Identity Guidelines: Authentication and Lifecycle Management," NIST Special Publication 800-63B, National Institute of Standards and Technology, Jun. 2017, updated 2020. [Online]. Available: https://pages.nist.gov/800-63-3/sp800-63b.html

[4] S. Rose, O. Borchert, S. Mitchell, and S. Connelly, "Zero Trust Architecture," NIST Special Publication 800-207, National Institute of Standards and Technology, Aug. 2020. [Online]. Available: https://doi.org/10.6028/NIST.SP.800-207

[5] National Institute of Standards and Technology, "Framework for Improving Critical Infrastructure Cybersecurity," NIST Cybersecurity Framework Version 1.1, Apr. 2018. [Online]. Available: https://doi.org/10.6028/NIST.CSWP.04162018

[6] A. Ometov, S. Bezzateev, N. Makitalo, S. Andreev, T. Mikkonen, and Y. Koucheryavy, "Multi-Factor Authentication: A Survey," Cryptography, vol. 2, no. 1, p. 1, Jan. 2018. [Online]. Available: https://doi.org/10.3390/cryptography2010001

[7] A. Shostack, Threat Modeling: Designing for Security. Indianapolis, IN: Wiley, 2014.

[8] U.S. Department of Health and Human Services, "Health Insurance Portability and Accountability Act Security Rule," 45 CFR Parts 160 and 164, HHS Office for Civil Rights. [Online]. Available: https://www.hhs.gov/hipaa/for-professionals/security/index.html

[9] U.S. Senate Committee on Finance, "Written Testimony of Andrew Witty, CEO, UnitedHealth Group," May 1, 2024. [Online]. Available: https://www.finance.senate.gov/hearings/the-change-healthcare-cyberattack-and-its-impact-on-small-physician-practices

[10] D. Stinson and M. Paterson, Cryptography: Theory and Practice, 4th ed. Boca Raton, FL: CRC Press, 2018.